

Bugbounty Roadmap

Research Report

Introduction

A Bug Bounty Program Roadmap is a structured plan designed to guide individuals from a beginner level to becoming successful and effective bug bounty hunters. The primary goal of a bug bounty hunter is to legally and ethically discover vulnerabilities in web applications, software, and systems, and report them to the organization in exchange for a reward. This roadmap focuses on establishing the necessary foundational knowledge, mastering essential security tools, and adopting a systematic methodology to maximize success in the competitive field of offensive security research.

Purpose

- Provide a clear path. Outline a progressive learning journey for aspiring bug bounty hunters. From fundamental concepts to advanced techniques
- Identify core requirements. Detail the essential technical skills, security knowledge, and specialized tools required for effective vulnerability discovery.
- Standardize Methodology. Promote the use of systematic testing methods.
- Facilitate Engagement. Guide the researchers on how to select programs, adhere to scope and write high quality vulnerability reports that lead to accepted submissions and payouts.

Methodologies and Approach

The recommended methodology is broken down into three phases:

1. Foundation
2. Tooling & Systemic Methodology
3. Practice

1. Foundation and Learning involves learning about several key concepts that are required to have an attempt at a bug bounty program. I.e

Networking - TCP/IP, HTTP/HTTPS protocols, DNS, proxies, and network traffic analysis.

Web Technologies - Deep understanding of HTML, CSS, JavaScript, AJAX, JSON, and the difference between client-side and server-side processing.

Programming - Proficiency in scripting languages is a must. Python, Ruby and Bash are few examples.

Core Security Concepts - Authentication, authorization, session management, encryption and the OWASP top 10 vulnerabilities.

2. Tooling involves mastering a set of tools for efficiency and scale. Some useful tools are:

BurpSuite - The industry standard tool for intercepting, modifying, and analyzing all web traffic.

Subfinder, Amass, Aquatone - For discovering subdomains, finding hidden files, and visual asset discovery.

Nuclei, Nikto - For identifying common misconfigurations and using community-driven templates to check for known vulnerabilities.

Systemic Methodologies is about creating checklists, mindmaps and recon pipelines.

Checklists - Use pre-defined lists (e.g., based on the OWASP Testing Guide) to ensure every vulnerability class is tested against every endpoint.

Mindmaps - Create a visual map of the target application, branching from the main domain to subdomains, and then to specific features (Login, API endpoints, file uploads) to organize the attack surface.

Recon Pipeline: Develop and automate a repeatable set of steps for initial information gathering (subdomain, port, directory discovery).

3. *Practice*. It is about repeatedly applying what you have learnt.

There are several practice labs such as Hack The Box, TryHackMe to test your skills in a controlled, legal environment.

Following the reporting standard is a must. They must be clear, concise, and contain the following structure:

Title: High-level summary of the issue.

Vulnerability Description: Technical explanation of the flaw.

Proof of Concept (PoC): Detailed, reproducible steps and evidence (screenshots/videos).

Impact: The security risk posed to the organization and its users.

Remediation: Suggested fix.

Importance

A formal bug bounty roadmap is vital because:

- **It mitigates analysis paralysis:** The sheer volume of security knowledge can be overwhelming; the roadmap breaks it down into manageable, actionable steps.
- **It ensures professional standards:** By emphasizing structured methodologies (checklists/mindmaps) and high-quality reporting, the roadmap trains researchers to think like security professionals, not just hackers.
- **It increases program ROI:** Researchers who follow a structured methodology are more likely to find novel and critical bugs, providing greater value to the companies running the bug bounty programs.

List of Bug Bounty Platforms

1. Bugcrowd
2. Hackerone
3. YesWeHack
4. Intigrity



Test websites

altoro.testfilre.net

demo.testfire.net

testphp.vulnweb.net

hackthissite.org

Practical

A short demo where I write a simple bash script to run multiple tools (nikto and nmap) on the same IP address at once. This avoids manually running multiple commands on the same IP twice or thrice, depending on the number of tools used.

```
GNU nano 8.4 test.sh *
IP=$1

# Run nikto on the given IP and use &
# to run it in background
nikto -h "$IP" &

# Similarly, run nmap on the ip
# in background
nmap -Pn "$IP" &

[]

^G Help      ^O Write Out ^F Where Is  ^K Cut
^X Exit      ^R Read File ^\ Replace   ^U Paste
```

```

(kali@kali)-[~]
$ bash ./test.sh 65.61.137.117

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 20:03 IST
(kali@kali)-[~]
$ - Nikto v2.5.0

+ Target IP: 65.61.137.117
+ Target Hostname: 65.61.137.117
+ Target Port: 80
+ Start Time: 2025-12-07 20:03:26 (GMT5.5)

+ Server: Apache-Coyote/1.1
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the page in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/missing-content-type-header/
Nmap scan report for 65.61.137.117
Host is up (0.31s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https
8080/tcp   open  http-proxy
8443/tcp   closed https-alt

```

Conclusion

The journey into bug bounty hunting is continuous and requires dedication to learning both fundamental concepts and the rapid evolution of technology. By adhering to a methodical roadmap that prioritizes strong foundational skills, mastery of essential tools, and the systematic use of organizational aids like checklists and mindmaps, a researcher can effectively navigate the complexities of vulnerability discovery. Ultimately, success is achieved through consistent practice, ethical conduct, and the ability to submit clear, high-impact vulnerability reports.